

CyberDefense Pro 2.0

2.1.2 Policy and Governance

This lesson covers the following topics:

- The role of governance
- The importance of policy
- Service level objectives

The Role of Governance

It is easy for technologists to overlook the impact and importance of effective leadership. While technology is at the heart of a security program, selecting appropriate technologies to address carefully analyzed problems is critically important. Looking for quick fixes is understandable, considering the potential impact of cybersecurity incidents. The reality is that when technology projects are driven by emotion, poorly planned, poorly designed, and implemented in a rush, they do little to improve the organization's security posture meaningfully. It does not take much research to identify that data breaches continue to increase rapidly, but spending on cybersecurity products is also growing in parallel. One very reasonable conclusion to this disunion is that technology alone is ineffective. Spending money on technology alone does very little. Only when technology is managed correctly are its actual impacts realized. Regardless of the technology brand or its features, proper planning and management are necessary to succeed!

The desire for successful technology implementation outcomes drives the need for a program designed to provide critical risk information to leadership teams. In turn, leadership teams are responsible for crafting effective responses by changing policies and processes to reflect their objectives. Establishing governance, risk, and compliance (GRC) teams is a common strategy to accomplish this goal. Governance teams drive the company's direction and respond to risks. Decisions made by governance teams are grounded in the information risk managers provide. Risk managers look to compliance teams to help identify if observed business practices align with established rules.

Ultimately, governance teams are responsible for creating and maintaining organizational policies used to direct the work of technical teams. Governance defines the organization's expectations of its employees and its approach to cybersecurity.

The Importance of Policy

Policy and procedure documents become roadmaps. When properly constructed, policy and procedure documents provide guidance and clear direction. Clear guidance and rules are critical in cyber operations where one decision or omission can differentiate between effective incident response or disaster. Security operations centers (SOCs) depend upon well-established incident-handling practices and clearly defined responses. It is easy to make mistakes when working under pressure. Well-crafted policies and procedures define response actions and often remove much of the judgment needed when deciding under pressure. Additionally, policies and procedures steer employees' work to ensure consistent and reliable performance.

Compliance teams depend upon policy documents and SLOs to measure work performance and conformance. Actionable statements can be extracted from policies and used to determine if work is being performed in a compliant manner. Furthermore, when risk managers identify new risks, the expectation is that governance teams will codify responses designed to address them by updating policy. This entire process is dependent upon the written rules established in policy documents!

For example, compliance teams may review patch management activities and report to risk managers regarding the time between issuing and applying a security patch. Risk managers use this data to create a trend report identifying that "time to patch" has increased steadily over the last several months. In response to this new risk item, risk managers work to determine that several change requests related to security patching have had their implementation dates pushed back by department leaders. This information is provided to the governance team responsible for crafting a response. The governance team's response might be to establish that any requests to delay security patching require two levels of management approval. The governance team would then codify this decision in the existing change management policy, enabling enforcement.

Service Level Objectives

Service level objectives (SLOs) define the level of service that a customer can expect from a specific service. SLOs are measurable targets, created upstream and typically expressed as uptime percentages, response times, or error rates. These measurements are usually accompanied by penalties or incentives for meeting or failing to meet the targets. SLOs help to establish clear expectations for service quality and provide a framework that can be used to measure and monitor performance over time. They should be aligned with the overall business objectives and should be reviewed regularly to ensure pertinence.

Copyright © CompTIA, Inc. All rights reserved.